

[SCC-4179](#)

Restrict CPNI field access to permission set only

Description

Remove FLS access to CPNI fields; delegate via permission set only

Per review with Matt Evrates, the System Administrator, System Administrator - API Only, and Standard User profiles should no longer have Field-Level Security access to CPNI Pin or CPNI Password.

- Remove read and edit FLS for both fields from the three named profiles and from every other profile or permission set that grants access in UAT or Production.
- Access to these fields will be granted **exclusively** through the permission set **"Contact Encrypted CPNI Read/Write Access."**
- This permission set allows assigned users to view the fields on the page layout without profile-level FLS.

Attached is an example

Public Label: CPNI Password		Save Cancel	
Data Type: Text (Encrypted/SB)			
Field-Level Security for Profile		☐ Visible	☐ Read-Only
Analytics Cloud Integration User		☐	☐
Analytics Cloud Security User		☐	☐
Anycloud Integration		☐	☐
Contract Manager		☐	☐
CPQ Integration User		☐	☐
Customer Community Plus Login User		☐	☐
Customer Community Plus User		☐	☐
End User		☐	☐
Executive Sponsor		☐	☐
GPC-BI & Reporting		☐	☐
GPC-Billing		☐	☐
GPC-Customer Service		☐	☐
GPC-Executive		☐	☐
GPC - Integration API User		☐	☐
GPC-Int. Engineering		☐	☐
GPC-PMO		☐	☐
GPC-ProSales Creating Support		☐	☐
GPC-Residential CMC Team		☐	☐
GPC-Sales		☐	☐
Identity User		☐	☐
Marketing User		☐	☐
Minimum Access - API Only Integrations		☐	☐
Minimum Access - Salesforce		☐	☐
Partner Community User		☐	☐
Read Only		☐	☐
Salesforce API Only System Integrations		☐	☐
Sales Insights Integration User		☐	☐
Salesman Manager		☐	☐
Standard User		☐	☐
System Administrator		☐	☐
System Administrator - API Only		☐	☐

As A

Devops

I Want

Additional CPNI Security

Acceptance Criteria

Pass only when Contact.CPNI_Pin__c and Contact.CPNI_Password__c are unreadable and uneditable through every profile and every non-approved permission set, and read/edit access remains only in "Contact Encrypted CPNI Read/Write Access." Validate both UI and API behavior with named users.

OH Requirement ID Field

None

Architecture

Solution Review

Use declarative FLS only: remove both CPNI field permissions from all profiles and all non-approved permission sets; retain read/edit access only in Contact Encrypted CPNI Read/Write Access. No field schema, Apex, Flow, or page-layout change is required.

Read-only verification on 26 August 2026: changes are still required before promotion. GreatPlainsMerge has CPNI access through the three named profiles plus Account and Contact - Full Access and Heroku and Data Hub Permissions. GreatPlainsUAT also has profile access through Product, GPC-BI & Reporting, and GPC-Residential CRC Team. The intended permission set correctly grants read/edit in both sandboxes.

Solution Type

Declarative Only

Architectural Status

Approved design; implementation changes required before deployment

Field Label	CPNI Password	Save	Cancel
Data Type	Text (Encrypted/SSE)		

Field-Level Security for Profile	Visible	Read-Only
Analytics Cloud Integration User	☐	☐
Analytics Cloud Security User	☐	☐
Anypoint Integration	☐	☐
Contact Manager	☐	☐
CPQ Integration User	☐	☐
Customer Community Plus Login User	☐	☐
Customer Community Plus User	☐	☐
End User	☐	☐
Executive Sponsor	☐	☐
GPC-BI & Reporting	☐	☐
GPC-Billing	☐	☐
GPC-Customer Service	☐	☐
GPC-Executive	☐	☐
GPC - Integration API User	☐	☐
GPC-Int. Engineering	☐	☐
GPC-PMO	☐	☐
GPC-ProSales Costing Support	☐	☐
GPC-Residential GPC Team	☐	☐
GPC-Sales	☐	☐
Identity User	☐	☐
Marketing User	☐	☐
Middleware Access - API Only Integrations	☐	☐
Middleware Access - Salesforce	☐	☐
Partner Community User	☐	☐
Read-Only	☐	☐
Salesforce API Only System Integrations	☐	☐
Sales Insights Integration User	☐	☐
Solution Manager	☐	☐
Standard User	☐	☐
System Administrator	☐	☐
System Administrator - API Only	☐	☐

Deployment

- Disposition: not ready for promotion. No Salesforce changes were made during this review.
- GreatPlainsMerge (00DEa00000GkAsHMAV): the target permission set has 1 assignment; both named fields are still exposed through 3 profiles and 2 additional permission sets.
- GreatPlainsUAT (00DEa00000FZILBMA1): the target permission set has 2 assignments; both named fields are still exposed through 6 profiles and 2 additional permission-set definitions.
- Production was not inspected or changed. Its complete profile, permission-set, and assignment inventory is a mandatory pre-deployment gate.

Testing Recommendation

Test case 1 - Negative access without the target permission set

1. Use an approved UAT user on each affected profile and confirm Contact Encrypted CPNI Read/Write Access is not assigned.
2. Open the same synthetic UAT Contact in the record page and Edit action; confirm CPNI Pin and CPNI Password are absent.
3. Run an approved API/SOQL check as that user; confirm neither field can be queried or updated.

4. Repeat for every profile and non-approved permission set identified by the final FLS inventory.

Test case 2 - Positive access through the target permission set

1. Use a named UAT user assigned only Contact Encrypted CPNI Read/Write Access for these fields.
2. Open the same synthetic UAT Contact; confirm both fields are visible and editable.
3. Enter approved synthetic values, save, reopen the record, and confirm the values persist and render with the expected encrypted-field masking.
4. Verify UI and approved API behavior, then remove any temporary test assignment or data according to the UAT cleanup plan.

Test case 3 - Exclusivity and regression

1. Query all FieldPermissions rows for both fields and prove the target permission set is the only remaining read/edit grant path.
2. Regression-test approved integrations and reporting users that previously depended on profile or broad permission-set access.
3. Capture user, profile, permission-set assignments, record ID, timestamps, expected result, actual result, and screenshots in the SCC-4179 evidence.

Runtime status: pending. No user assignment, Contact record, metadata, deployment, or activation was changed during this read-only completion review.

Pre-Deployment

1. Retrieve and archive the current Production metadata for both Contact fields, every profile, and every permission set that grants either field.
2. Inventory current target-permission-set assignees and obtain Security/Data Owner approval for the final authorized-user list.
3. Build a focused package that removes read/edit from every unauthorized access path while preserving read/edit in Contact_CPNI_Read_Write_Access.
4. Assess integrations, reports, list views, and automated users that may rely on the two fields; obtain owners and regression tests before removal.
5. Run a check-only validation against the target org, record the job ID and exact components, and obtain explicit deployment approval.

Deployment

1. Deploy only the approved, focused profile and permission-set FLS changes; do not modify field definitions, layouts, Apex, Flow, or unrelated permissions.
2. Retain read=true and edit=true only for Contact.CPNI_Pin__c and Contact.CPNI_Password__c in Contact_CPNI_Read_Write_Access.
3. Remove both field-permission entries, or set read/edit false as supported, in every profile and non-approved permission set found by the inventory.
4. Deploy to GreatPlainsUAT first. Promote to Production only after named-user UAT, integration regression, Security approval, and an approved change window.
5. Record the deployment job ID, final component count, test level/result, start/end time, and any omissions. Do not auto-assign the permission set to new users.

Post-Deployment

1. Read back FieldPermissions for both fields and confirm no profile or non-approved permission set grants read or edit.
2. Confirm the target permission set still grants read/edit and its assignee list exactly matches the approved list.
3. Execute the negative, positive, exclusivity, and integration regression tests above with named users.
4. Review Setup Audit Trail and deployment results, attach evidence to SCC-4179, and obtain Business, Security, and QA sign-off.
5. If a critical dependency fails, roll back with the approved metadata backup and remove any emergency assignment after the incident is resolved.

DevOps Assignee

Salesforce Release Manager / Salesforce Administrator; record the named owner before the change window.

DevOps Required

Yes

Board

Development

Attachments

1

Technical Documentation

Libraries/Packages Used

None. Standard Salesforce profile, permission-set, and Field-Level Security metadata only.

APIs

No runtime API is introduced. Use Metadata API for the approved deployment and SOQL read-back of FieldPermissions and PermissionSetAssignment for verification.

Triggers or Automations

None. No Apex trigger, Flow, validation rule, or automation change is required.

New or Updated Objects/Fields

No object or field schema change. Existing fields referenced: Contact.CPNI_Pin__c and Contact.CPNI_Password__c.

Components

New: none. Update: Profiles - System Administrator, System Administrator - API Only, Standard User, plus every additional Production/UAT profile found by inventory (UAT currently includes Product, GPC-BI & Reporting, and GPC-Residential CRC Team).
Permission Sets - preserve Contact_CPNI_Read_Write_Access; remove both field grants from Account_and_Contact_Full_Access, Heroku_and_Data_Hub_Permissions, and any other non-approved grant path found in Production.

Settings Modifications

Field-Level Security only: remove both field grants from every profile and non-approved permission set; preserve read/edit only in Contact_CPNI_Read_Write_Access.

Error Logging

No application logging change. Release evidence must include validation/deployment results, Setup Audit Trail, FLS read-back, and named-user UAT results.

Temporal Changes

Permanent least-privilege control. Any emergency access must use the approved permission set, be time-bounded by process, and be removed after the approved window.